Running an Effective Vulnerability Management Program

An InfoSec Practitioner's Guide

AGENDA

01 Introduction & Why VM Matters

02 Core Components of a VM Program

03 Risk-Based Prioritization

04 Remediation Workflows

05 Metrics & Reporting

06 Governance & Maturity

07 Common Pitfalls

08 Tooling & Special Considerations

09 Building Organizational Buy-In

10 Key Takeaways

What Is Vulnerability Management & Why It Matters

Definition

VM is a continuous process of identifying, classifying, prioritizing, remediating, and mitigating software and system vulnerabilities.

The Stakes

The average cost of a data breach exceeded $4.4M in 2025. Unpatched vulnerabilities remain one of the top attack vectors.

Source: IBM Data Breach Report 2025
https://www.ibm.com/reports/data-breach

It's a Program

VM is not a one-time scan or a tool purchase. It's an ongoing discipline requiring people, process, and technology.

Building Blocks of a VM Program

1

Asset Inventory

You can't protect what you don't know you have. A comprehensive, up-to-date CMDB is the foundation.

2

Vulnerability Scanning

Authenticated & unauthenticated scans. Internal, external, and cloud. Scheduled + continuous.

3

Penetration Testing

Complements scanning with human-led exploitation. Validates real-world attack paths.

4

Threat Intelligence

Enrich findings with exploit data, active campaigns, and adversary TTPs to focus effort.

Why Patching Everything Isn't a Strategy

Risk Score = f(

CVSS Score	*Useful baseline, not sufficient alone*
Exploitability (EPSS)	*How likely is active exploitation?*
CISA KEV Catalog	*Known exploited vulnerabilities in the wild*
Asset Criticality	*Crown jewels vs. dev sandbox?*
Data Sensitivity	*PII, PCI, PHI exposure?*
Exposure / Reachability	*Internet-facing vs. isolated?*

PRIORITY MATRIX*

CRITICAL	SLA: 24–72 hours
HIGH	SLA: 30 days
MEDIUM	SLA: 90 days
LOW	SLA: 180 days / risk accept

SLA's will vary by Organization.

From Discovery to Resolution

Discover → Prioritize → Assign Owner → Remediate / Mitigate → Verify & Close

Ownership Model

- Security team: identifies & tracks
- IT Ops: OS & infrastructure patches
- Dev teams: application vulns
- Defined in RACI matrix

Tooling Integration

- Ticket creation in ITSM Solution
- Auto-assign by asset owner
- SLA tracking & escalation alerts
- Closure verified by re-scan

Exceptions & Escalation

- Formal risk acceptance process
- Time-limited exceptions only
- Compensating controls documented
- CISO/Business Executive sign-off for Critical/High

Measuring What Matters

MTTR	SLA%	CVD	COV%
Mean Time to Remediate	**SLA Compliance Rate**	**Vuln Density**	**Scan Coverage**
Track by severity tier	*% patched within target*	*Vulns per asset (trending)*	*% of assets scanned*

Tailor Reporting to Your Audience

Technical Teams

Scan results, ticket queues, SLA breaches, vuln details

Executives

Risk posture trend, top risks, resource needs, compliance status

Board

Cyber risk in business terms: financial exposure, peer comparison, regulatory risk

Program Structure & Compliance Alignment

Policy & Procedure

Document VM policy, scanning cadence, SLAs, and exception handling process.

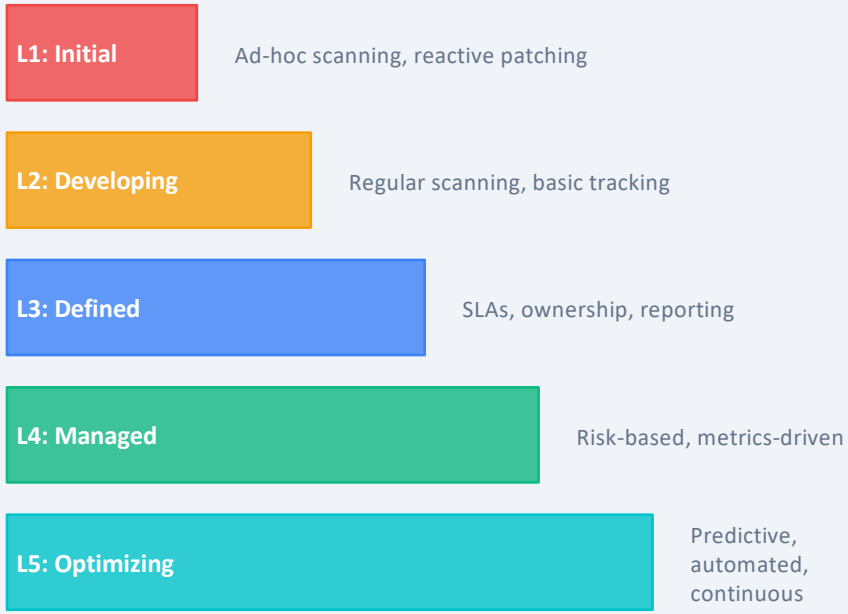
RACI Model

Define who is Responsible, Accountable, Consulted, and Informed for each phase.

Compliance Alignment

Map controls to PCI-DSS, HIPAA, SOC 2, NIST CSF, and ISO 27001 requirements.

VM Maturity Model



What Breaks VM Programs

Scan Theater

Scanning without fixing. Metrics look busy; risk doesn't decrease.

Alert Fatigue

Too much noise drowns out real risk. Prioritization is the antidote.

Coverage Gaps

Shadow IT, cloud sprawl, OT/IoT devices fall outside scan scope.

Siloed Teams

Security finds; nobody owns remediation. Shared accountability is essential.

CVSS Fixation

Chasing CVSS 10s while actively exploited medium vulns go unpatched.

No Exception Process

Vulns linger with no documented risk decision. Creates audit risk.

Technology & Unique Environments

Vulnerability Scanners

Tenable Nessus, Qualys VMDR, Rapid7 InsightVM, Wiz (cloud)

RBVM / ASPM Platforms

Nucleus Security, Ivanti, Brinqa, ArmorCode — aggregate & prioritize across sources

Integration Layer

SIEM (Splunk, Sentinel), SOAR, CMDB (ServiceNow), ticketing (Jira)

AppSec Tooling

SAST, DAST, SCA — essential for application-layer coverage

Special Environments

☁️ **Cloud Native**

Ephemeral assets, IaC scanning, container image scanning

🏭 **OT / ICS**

Passive scanning only; availability > confidentiality

📦 **Supply Chain**

SBOM, third-party risk, dependency scanning (SCA)

📱 **Mobile & IoT**

Often missed by traditional scanners; custom approaches needed

Getting the Whole Organization Behind VM

Executives

- Translate risk into dollars
- Benchmark against peers
- Tie to regulatory exposure
- Show trend improvement over time

Engineering & IT Ops

- Involve them in tool selection
- Reduce ticket noise via prioritization
- Celebrate fast remediators
- Automate where possible

The Broader Org

- Quick wins to show early value
- Regular comms on risk reduction
- Make security a shared mission
- Get exec sponsor visible

What to Remember

1. VM is a program, not a project — it requires continuous improvement and dedicated ownership.
2. Prioritization and accountability are the two hardest problems. Solve these first.
3. Start with visibility: know your assets, know your exposure, then build toward risk-based maturity.
4. Metrics drive behavior — measure MTTR, SLA compliance, and coverage, not just vuln counts.
5. Security is a team sport. Without buy-in from IT, engineering, and leadership, VM programs stall or fail completely.

Questions & Discussion